Universidad del Desarrollo

Seguridad y Protección de Datos – Proyecto Integrador

Actividad N°6

Implementación de los mecanismos de derechos de los titulares

Caso 1: NortiShop (comercio electrónico)

Integrantes: Ignacia Castillo, Milan Kurte, Francisco Polo

Fecha: 08/11/2026

Repositorio: github.com/m1lvn/nortishop-seguridad (rama actividad6)

Índice

1. Introducción 3
1.1 Alcance y normativa aplicable 3
1.2 Punto de partida y qué se agregó 3
2. Canal de solicitudes y modelo de datos 4
2.1 Canal 4
2.2 Modelo de datos de la solicitud 5
2.3 Seguimiento 6
3. Verificación de identidad 7
4. Acceso y portabilidad 8
5. Rectificación con registro del cambio 10
6. Supresión 11
6.1 Condiciones 11
6.2 Qué se elimina, qué se bloquea por obligación legal y cómo se propaga 11
7. Oposición y bloqueo del tratamiento 14
7.1 Tratamiento elegido 14
7.2 Oposición 15
7.3 Bloqueo temporal 15
8. Pruebas de cada mecanismo 18
9. Limitaciones 20
10. Referencias 20
Anexo A. Cumplimiento de la pauta 21

1. Introducción

1.1 Alcance y normativa aplicable

Esta actividad completa los mecanismos con los que un titular ejerce sus derechos frente a NortiShop. Parte del inventario de datos personales (informe de inventario y clasificación) y del módulo de consentimiento de la Actividad 5: el inventario dice qué datos hay que entregar, corregir, suprimir o bloquear y dónde están; el módulo de consentimiento dice con qué base legal se trata cada finalidad, lo que decide si al titular le corresponde revocar un consentimiento u oponerse a un tratamiento.

El análisis se hace con la Ley 19.628 modificada por la Ley 21.719: acceso (art. 5°), rectificación (art. 6°), supresión y sus excepciones (art. 7°), oposición (art. 8°), bloqueo temporal del tratamiento (art. 8° ter), portabilidad (art. 9°), gratuidad y medios (art. 10) y procedimiento ante el responsable (art. 11: solicitud escrita, autenticación del titular, respuesta dentro de 30 días corridos prorrogables una vez por 30, y aviso del plazo para reclamar ante la Agencia cuando se deniega).

1.2 Punto de partida y qué se agregó

La Actividad 5 ya tenía el flujo de solicitudes, la verificación por correo y los derechos de acceso, portabilidad, rectificación y supresión. En esta actividad se completaron los puntos que la pauta exige y que faltaban o estaban incompletos:

Tabla 1. Cambios de la Actividad 6.

Pauta	Antes (Actividad 5)	Ahora (Actividad 6)
1. Canal y modelo	Web y API, sin registrar por qué canal llegó la solicitud	Columna canal (web/api), tratamiento (oposición), asociada (bloqueo) y acta (supresión) en solicitudes_derechos
2. Verificación	Contraseña + código al correo	Igual, extendida a oposición y bloqueo; ningún tipo se ejecuta sin verificar
3. Acceso y portabilidad	Mismo contenido para ambos	Acceso agrega historial de rectificaciones, oposiciones y bloqueos; portabilidad entrega solo lo aportado por el titular (art. 9°)
4. Rectificación	Bitácora con los nombres de los campos	Tabla registro_rectificaciones: valor anterior y nuevo cifrados, fecha, solicitud y a quién se comunicó (art. 6°); inmutable; aviso al titular
5. Supresión	Borrado con texto fijo de respuesta	Acta con lo eliminado, lo bloqueado por obligación legal (pedidos con bloqueo_legal_hasta, 6 años) y lo propagado (pasarela, respaldos)
6. Oposición o bloqueo	No existía	Tratamiento encuesta_satisfaccion (interés legítimo) con oposición; bloqueo temporal asociado a una solicitud en curso (art. 8° ter)
7. Pruebas	47 pruebas de la Actividad 5	19 pruebas nuevas (pruebas_actividad6.py), cada una con una solicitud concreta; total 92/92

2. Canal de solicitudes y modelo de datos

2.1 Canal

El titular presenta la solicitud por escrito y por un medio electrónico, como pide el art. 11, a través de dos canales que usan exactamente las mismas funciones de servicio de derechos.py (los controles no cambian según el canal):

Tabla 2. Canales de solicitud.

Canal	Cómo se usa	Autenticación de la sesión
Web	Mi cuenta > Mis derechos: un formulario por derecho (acceso/portabilidad, rectificación, supresión, oposición y bloqueo). Cada solicitud tiene una página de seguimiento.	Cookie de sesión segura + token anti-CSRF en cada formulario
API	POST /api/v1/derechos con tipo y los datos del tipo; /verificacion, /codigo, /correo-nuevo, /exportacion para continuar.	Token Bearer; la cookie no sirve en la API
Privacidad (interno)	Bandeja /privacidad/solicitudes y POST /api/v1/privacidad/solicitudes/<código>: evalúa supresiones y oposiciones, prorroga plazos.	Rol privacidad (RBAC)

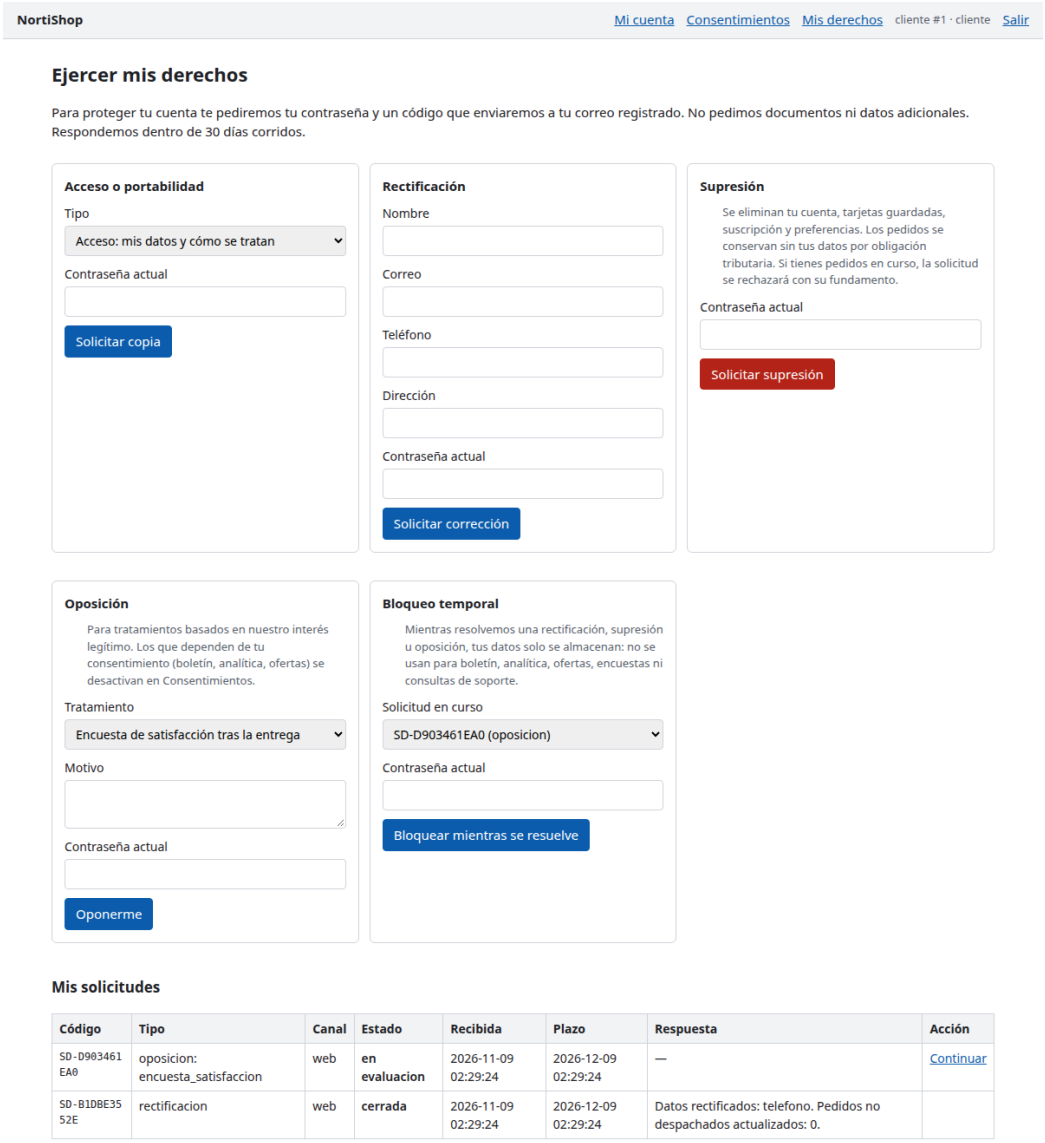


Figura 1. Canal web: un formulario por derecho, incluidos oposición y bloqueo temporal.

2.2 Modelo de datos de la solicitud

Cada solicitud es una fila de solicitudes_derechos. La fila sirve a la vez de registro (qué se pidió, por qué canal, quién) y de seguimiento (en qué etapa está y cuánto plazo queda). No guarda nombre ni correo: el titular se referencia por su id interno y por un seudónimo (HMAC) que la bandeja de privacidad muestra en vez de la identidad.

Tabla 3. Columnas de solicitudes_derechos.

Columna	Contenido
codigo	Identificador público aleatorio (SD- + 10 hex), el que ve el titular
cliente_id / titular_seudonimo	Titular (id interno; NULL tras la supresión) y su seudónimo HMAC para el seguimiento

Columna	Contenido
tipo	acceso, portabilidad, rectificacion, supresion, oposicion, bloqueo (CHECK)
canal	web o api (CHECK) — **nuevo**
tratamiento	Oposición: finalidad a la que se opone (llave foránea a finalidades) — **nuevo**
asociada	Bloqueo: solicitud de rectificación, supresión u oposición que lo motiva — **nuevo**
estado	recibida → verificada → en_evaluacion → ejecutada | rechazada → cerrada (CHECK y máquina de estados)
fecha_recepcion … fecha_cierre	Fecha y hora UTC de cada etapa
plazo_vence, prorrogada	Recepción + 30 días corridos; una sola prórroga de 30 días con motivo
resultado	Respuesta fundamentada al titular; al rechazar incluye el plazo para reclamar ante la Agencia
detalle_cifrado	Valores nuevos de una rectificación o motivo de una oposición, cifrados (AES-256-GCM); se borran al resolver
evaluador_id	Persona de privacidad que resolvió
acta	Supresión: JSON con lo eliminado, bloqueado y propagado (solo cantidades) — **nuevo**

Tabla 4. Tablas de apoyo.

Tabla	Para qué
verificaciones_identidad	HMAC del código de un solo uso, propósito (titular o correo nuevo), vencimiento, intentos y uso
registro_rectificaciones	Una fila por campo rectificado: valor anterior y nuevo cifrados, fecha, solicitud y destinatarios comunicados — **nueva**
oposiciones	Oposición acogida: titular, tratamiento, solicitud y fecha; los procesos la consultan en cada ejecución — **nueva**
bloqueos	Bloqueo temporal: titular, solicitud, solicitud asociada, desde y hasta (NULL = vigente) — **nueva**
lista_supresion	Índices HMAC de correos suprimidos, para reaplicar la supresión al restaurar un respaldo

2.3 Seguimiento

La única forma de cambiar el estado es la función _cambiar_estado, que valida la transición y escribe la fecha de la etapa. Al cerrar una solicitud levanta además cualquier bloqueo asociado. El titular ve el estado, el plazo y la respuesta en Mis solicitudes; privacidad ve en su bandeja los días restantes de cada solicitud, sin nombres ni correos. Cada paso queda en la bitácora encadenada de la Actividad 5 con el canal y sin valores.

Solicitud concreta por la web: Carla pide acceso a sus datos (seguimiento de cada etapa)

```
 recibida  : recibida  plazo_vence=2026-12-09 02:28:03
 verificada: en_evaluacion
 codigo       | tipo   | canal | estado  | fecha_recepcion     | fecha_verificacion  | fecha_cierre        | plazo_...
 -------------+--------+-------+---------+---------------------+---------------------+---------------------+-------...
 SD-A03BC76131 | acceso | web   | cerrada | 2026-11-09 02:28:03 | 2026-11-09 02:28:03 | 2026-11-09 02:28:03 | 2026-1...

Solicitud concreta por la API: Beto pide portabilidad
 POST /api/v1/derechos -> 201 {'codigo': 'SD-67BDBE2395', 'estado': 'recibida'}
 codigo       | tipo        | canal | estado   | fecha_recepcion     | plazo_vence
 -------------+-------------+-------+----------+---------------------+--------------------
 SD-67BDBE2395 | portabilidad | api   | recibida | 2026-11-09 02:28:03 | 2026-12-09 02:28:03

Bandeja de privacidad (seguimiento sin datos personales: el titular es un seudónimo):
 codigo       | tipo        | canal | estado   | dias_restantes | titular
 -------------+-------------+-------+----------+----------------+------------
 SD-A03BC76131 | acceso      | web   | cerrada  | 29             | 6842fadfb98e
 SD-67BDBE2395 | portabilidad | api   | recibida | 29             | 0f537d4a3bec
```

Figura 2. Solicitudes concretas por la web y por la API, y bandeja de privacidad (evidencia/ev_act6_canal_modelo.txt).

3. Verificación de identidad

El art. 11 exige identificar y autenticar al titular. Como todas las solicitudes vienen de una cuenta, NortiShop ya tiene con qué verificar sin pedir datos nuevos (no se piden copias de carnet ni RUT, que el sistema no guarda). Se usan dos factores independientes:

1. **Algo que sabe:** al crear la solicitud se reingresa la contraseña, aunque la sesión esté abierta. Si falla, la solicitud no se registra.
2. **Algo que tiene:** un código de 6 dígitos enviado al correo registrado (nunca a un correo que indique el solicitante). En la base solo queda su HMAC; vence en 10 minutos, admite 3 intentos y se pueden emitir 3 códigos por solicitud. Al agotarse, la solicitud se rechaza y se cierra.
3. **Cambio de correo:** exige además un código enviado al correo nuevo, para probar que el titular lo controla. Después se avisa al correo anterior y al nuevo.

Hasta que la identidad se verifica, la solicitud queda en `recibida` y ninguna función la ejecuta: `exportar` exige `en_evaluacion`, la rectificación y el bloqueo se aplican solo dentro de `verificar_identidad`, y privacidad no puede resolver una supresión u oposición sin verificar. Una solicitud ajena o inexistente responde lo mismo (`Acceso denegado`), para no revelar si el código existe.

Tabla 5. Solicitudes de solicitantes no verificados probadas.

Caso	Qué intenta	Resultado
A. Sesión abierta sin contraseña	Pedir la supresión de Ana	AccesoDenegado; no se registra la solicitud ni se envía código
B. Contraseña robada sin acceso al correo	Cambiar el correo de Ana a uno del atacante	3 códigos incorrectos → rechazada y cerrada; el correo no cambia y nunca se escribe al correo del atacante
C. Otro cliente con el código de Ana	Verificar y descargar la exportación de Ana	AccesoDenegado en ambos; la solicitud sigue en recibida
D. Personal o petición sin sesión	Soporte crea una solicitud; POST a la API sin token	AccesoDenegado / 401

Caso	Qué intenta	Resultado
E. Bloqueo sin verificar	Pedir un bloqueo y probar códigos	No se crea ningún bloqueo; solicitud rechazada

```
Caso A - alguien con la sesión abierta de Ana pero sin su contraseña pide la supresión:
  crear_solicitud(supresion, password incorrecta)            -> AccesoDenegado: Acceso denegado
  solicitudes de supresión registradas: 0

Caso B - atacante con la contraseña robada de Ana, sin acceso a su correo, quiere cambiar el correo:
  verificar_identidad(código 000000)                         -> ValueError: El código es incorrecto o venció
  verificar_identidad(código 123456)                         -> ValueError: El código es incorrecto o venció
  verificar_identidad(código 999999)                         -> ValueError: El código es incorrecto o venció
  codigo       | tipo         | estado  | fecha_verificacion | resultado                                        ...
  -------------+--------------+---------+--------------------+-------------------------------------------------...
  SD-6154D5D861 | rectificacion | cerrada |                    | No se pudo verificar la identidad del solicitante. S...
  correo de Ana sigue siendo: ana@prueba.cl
  mensajes enviados a atacante@malo.cl: 0

Caso C - Beto obtiene el código de una solicitud de Ana e intenta usarlo:
  Beto verifica la solicitud de Ana                       -> AccesoDenegado: Acceso denegado
  Beto descarga la exportación de Ana                        -> AccesoDenegado: Acceso denegado
  estado de la solicitud de Ana: recibida

Caso D - personal y peticiones sin sesión:
  soporte crea una solicitud de acceso                       -> AccesoDenegado: Acceso denegado
  POST /api/v1/derechos sin token -> 401 {'error': 'Se requiere iniciar sesión'}

Caso E - la verdadera Ana verifica con el código de su correo:
  Ana verifica su solicitud de acceso                        -> OK en_evaluacion
```

Figura 3. Solicitantes no verificados (evidencia/ev_act6_verificacion.txt).



Figura 4. Una solicitud recibida espera el código enviado al correo registrado.

4. Acceso y portabilidad

Ambos derechos entregan un archivo JSON (`nortishop-export/1.0`) que se genera una sola vez, se descarga y no queda guardado en el servidor. El archivo se arma con una **lista blanca**: solo se leen las filas cuyo `cliente_id` es el del titular verificado, y de ellas solo los campos listados. Lo que no está en la lista no puede salir aunque se agregue una columna nueva a la base.

Tabla 6. Contenido del archivo.

Sección	Acceso (art. 5°)	Portabilidad (art. 9°)	Origen (inventario)
cuenta	nombre, correo, teléfono, dirección, NortiPuntos, fecha de la declaración de mayoría de edad	Lo mismo sin NortiPuntos (dato generado por NortiShop, no aportado)	clientes (descifrado)
tarjetas	marca y últimos 4 dígitos	Igual	tarjetas_guardadas (nunca el token)
pedidos	código, fecha, estado, monto, tarjeta enmascarada, región, dirección, productos	Igual	pedidos con cliente_id del titular
consentimientos	historial completo de otorgamientos y revocaciones	Igual	consentimientos
rectificaciones, oposiciones, bloqueos	Historial con valores anterior/nuevo y destinatarios	No (no son datos aportados)	tablas nuevas
informacion_tratamiento	Finalidades y base legal, destinatarios, interés legítimo, conservación, solicitudes	No	finalidades, solicitudes

Quedan fuera siempre: hash de la contraseña, tokens de la pasarela, índices HMAC, seudónimo, códigos de autorización, contadores de bloqueo de cuenta, la bitácora y cualquier dato de otro titular (otros clientes y pedidos de invitados).

```
Solicitud de acceso de Ana -> evidencia/ev_act6_acceso_ana.json
  secciones: formato, generado, solicitud, tipo, cuenta, tarjetas, pedidos, consentimientos, rectificaciones, oposici…
  pedidos exportados: ['NS-A254752C2783', 'NS-B8CBD20374DD']
  pedidos de Ana en la base: ['NS-A254752C2783', 'NS-B8CBD20374DD']
  consentimientos exportados / en la base: 2 / 2

Solo los datos de Ana (búsqueda de datos ajenos o internos en el archivo):
  correo de Beto          presente: False
  dirección de Beto       presente: False
  datos de Carla          presente: False
  invitado                presente: False
  hash de contraseña      presente: False
  token de pasarela       presente: False
  índice HMAC del correo  presente: False
  seudónimo               presente: False

Portabilidad de Beto (API): solo lo que él aportó, en JSON estructurado
  GET /api/v1/derechos/SD-67BDBE2395/exportacion -> 200, guardado en evidencia/ev_act6_portabilidad_beto.json
  secciones: consentimientos, cuenta, formato, generado, pedidos, solicitud, tarjetas, tipo
  campos de la cuenta: correo, direccion, mayoria_edad_declarada, nombre, telefono  (sin nortipuntos: dato generado p…
  Beto pide de nuevo la misma exportación                  -> ValueError: La solicitud no está lista para expor…
```

Figura 5. Acceso de Ana y portabilidad de Beto por la API: todos sus datos y solo los suyos (evidencia/ev_act6_acceso_portabilidad.txt).


```
{
  "consentimientos": [],
  "cuenta": {
    "correo": "beto@prueba.cl",
    "direccion": null,
    "mayoria_edad_declarada": "2026-11-09 02:28:02",
    "nombre": "Beto Prueba",
```

```
    "telefono": "+56 9 3333 4444"
  },
  "formato": "nortishop-export/1.0",
  "generado": "2026-11-09 02:28:04",
  "pedidos": [
   {
    "codigo": "NS-A87A97CEB480",
    "direccion": "Calle Beto 99, Ñuñoa",
    "estado": "pagado",
    "fecha": "2026-11-09 02:28:03",
    "monto": 25990,
    "productos": [
     {
      "cantidad": 1,
      "precio": 25990,
      "producto": "Teclado"
     }
    ],
    "region": "Metropolitana de Santiago",
    "tarjeta": "**** 4444"
   }
  ],
  "solicitud": "SD-67BDBE2395",
  "tarjetas": [
   {
    "marca": "MASTERCARD",
    "terminacion": "4444"
   }
  ],
  "tipo": "portabilidad"
}
```


Figura 6. Archivo de portabilidad entregado a Beto (evidencia/ev_act6_portabilidad_beto.json).

5. Rectificación con registro del cambio

El titular indica qué campos corregir. Solo se aceptan nombre, teléfono, dirección y correo (lista blanca); cualquier otro campo (rol, NortiPuntos) rechaza la solicitud completa. Cada valor pasa por las mismas validaciones del registro. Mientras espera la verificación, los valores nuevos quedan cifrados en detalle_cifrado.

Al verificarse, _ejecutar_rectificacion hace en una sola transacción:

- Actualiza la cuenta. Si cambia el correo, cambia su índice HMAC y por eso se vuelven a cifrar correo, teléfono y dirección (su contexto AAD incluye el índice).
- **Propaga** el dato corregido a quien lo recibió, como exige el art. 6°: la dirección nueva pasa a los pedidos pagados aún no despachados (lo que ve la empresa de despacho) y el correo nuevo a la lista del boletín. Los pedidos ya despachados conservan la dirección a la que efectivamente se enviaron.
- **Registra el cambio** en registro_rectificaciones: una fila por campo con el valor anterior y el nuevo cifrados (contexto rectificacion.<campo>.<anterior|nuevo>:<solicitud>), la fecha, la solicitud y los destinatarios a los que se comunicó. Un trigger impide modificar estas filas.
- Borra los valores de la solicitud (detalle_cifrado = NULL), la cierra con su resultado y avisa al correo anterior y al nuevo, para que el titular detecte un cambio que no hizo.

La bitácora sigue guardando solo los nombres de los campos (campos=direccion,telefono). Los valores están únicamente en el registro de rectificaciones, cifrados, y se entregan al titular en su próxima solicitud de acceso. El registro se elimina con la supresión de la cuenta.

```
Solicitud concreta: Beto corrige su dirección y teléfono. Tiene el pedido 3 pagado (aún no despachado).
  detalle_cifrado de la solicitud (valores nuevos): recibida, v1:jdg+uduVEZHE6gEA9fQwxlayhUYBenglY3uEZ...
  Beto verifica con el código del correo                    -> OK cerrada
  codigo       | estado  | fecha_verificacion  | fecha_cierre        | resultado                          ...
  -------------+---------+---------------------+---------------------+-------------------------------------------...
  SD-1700341995 | cerrada | 2026-11-09 02:28:04 | 2026-11-09 02:28:04 | Datos rectificados: direccion,telefono. Pedid...

registro_rectificaciones (crudo: valores cifrados):
  id | solicitud     | cliente_id | campo     | valor_anterior_cifrado  | valor_nuevo_cifrado     | fecha          ...
  ---+---------------+------------+-----------+-------------------------+-------------------------+------------------...
  1  | SD-1700341995 | 2          | direccion | NULL...                 | v1:0tUTGVMJJ5QbOpHKVn1... | 2026-11-09 02:28:...
  2  | SD-1700341995 | 2          | telefono  | v1:fuHyTFItmq6qHfyWV/p... | v1:dP7hAL3FZGPljCm+K3E... | 2026-11-09 02:28:...

El mismo registro descifrado (lo que verá Beto en su próxima solicitud de acceso):
  direccion  None                    -> Pasaje Nuevo 55, Ñuñoa
  telefono   +56 9 3333 4444         -> +56 9 7777 8888

Propagación:
  dirección que ve logística para el pedido 3: Pasaje Nuevo 55, Ñuñoa
  aviso al correo del titular: NortiShop: se rectificaron tus datos (SD-1700341995)

El registro no se puede alterar:
  UPDATE registro_rectificaciones SET campo='nombre'        -> IntegrityError: el registro de rectificaciones no...

Rectificación del correo (exige un segundo código enviado al correo nuevo):
  Carla verifica (código del correo actual)              -> OK en_evaluacion
  Carla confirma (código del correo nuevo)               -> OK cerrada
  solicitud     | campo  | fecha               | comunicado_a
  --------------+--------+---------------------+-------------------------------------
  SD-BB4508C589 | correo | 2026-11-09 02:28:04 | cuenta del cliente; lista del boletín
  avisos: correo anterior='NortiShop: se rectificaron tus datos (SD-BB4508C589)'
          correo nuevo   ='NortiShop: se rectificaron tus datos (SD-BB4508C589)'
```

Figura 7. Rectificación de dirección y teléfono de Beto y de correo de Carla (evidencia/ev_act6_rectificacion.txt).

6. Supresión

6.1 Condiciones

Una vez verificada, la supresión se evalúa automáticamente: si el titular tiene pedidos pagados o despachados se rechaza con fundamento (los datos se necesitan para cumplir el contrato, art. 7°) y se le indica que puede volver a pedirla tras la entrega. Si no hay pedidos en curso, pasa a privacidad, que la aprueba o la rechaza con un motivo escrito (por ejemplo, un reclamo pendiente). Ambos rechazos informan el plazo para reclamar ante la Agencia.

6.2 Qué se elimina, qué se bloquea por obligación legal y cómo se propaga

Tabla 7. Efecto de la supresión sobre cada dato del inventario.

Dato	Acción	Fundamento
Cuenta (nombre, correo, teléfono, dirección, contraseña, NortiPuntos)	**Elimina**	Art. 7°: el titular lo pide y no hay otra base
Tarjetas guardadas	**Elimina** y pide a la pasarela borrar el token de su bóveda	Ídem
Suscripción al boletín, comportamiento de compra	**Elimina**	Base: consentimiento, que se retira

Dato	Acción	Fundamento
Registro de rectificaciones, oposiciones, bloqueos, códigos de verificación	**Elimina**	Sin finalidad una vez cerrada la cuenta
Sesiones abiertas	**Revoca**	Nadie puede seguir usando la cuenta
Dirección de los pedidos	**Elimina**	Ya se cumplió el despacho
Pedidos (monto, fecha, productos, últimos 4 dígitos)	**Bloquea**: sin vínculo con la persona, bloqueo_legal_hasta = hoy + 6 años; fuera de las vistas operativas y sin poder modificarse; aplicar_retencion los borra al vencer	Art. 7° (obligación legal): respaldo contable y tributario; art. 200 del Código Tributario (revisión del SII de hasta 6 años)
Historial de consentimientos	**Bloquea** bajo seudónimo por 2 años y luego se borra	Prueba de licitud del tratamiento pasado (defensa ante reclamos)
Solicitudes de derechos	Quedan con seudónimo, sin cliente_id ni valores	Prueba de haber respondido dentro de plazo
Pasarela de pago (encargado)	**Propaga**: borra los tokens	El encargado trata por cuenta de NortiShop
Respaldos	**Propaga**: el índice del correo va a lista_supresion; reaplicar_supresiones borra la cuenta otra vez si se restaura un respaldo	La supresión debe sobrevivir a una restauración
Empresa de despacho	Sin envío: la supresión exige no tener pedidos en curso	—

suprimir_cliente devuelve un **acta** con esas tres partes, contadas por tabla y sin datos personales. Se guarda en la columna acta de la solicitud (privacidad la consulta con acta_supresion) y su resumen es la respuesta enviada al titular. La supresión se ejecuta antes de marcar la solicitud como ejecutada: si fallara, la solicitud seguiría en evaluación en vez de informar algo que no ocurrió.

```
Solicitud concreta 1: Ana pide la supresión teniendo el pedido 5 pagado (en curso).
  Ana verifica                                -> OK cerrada
  resultado: Existen pedidos en curso (pagados o despachados). Sus datos se necesitan para cumplir el contrato de com…

Se entregan los pedidos 2 y 5. Solicitud concreta 2: Ana vuelve a pedir la supresión.
  Ana verifica                                -> OK en_evaluacion

Antes de ejecutar:
  clientes              filas de Ana: 1
  tarjetas_guardadas    filas de Ana: 1
  boletin_suscriptores  filas de Ana: 1
  pedidos               filas de Ana: 2
  registro_rectificaciones  filas de Ana: 0
  comportamiento_compra     filas de Ana: 1
  tokens en la bóveda de la pasarela: 1
  marketing intenta aprobar la supresión          -> AccesoDenegado: Acceso denegado
  privacidad aprueba la supresión                 -> OK cerrada

Acta de la supresión (guardada en solicitudes_derechos.acta, sin datos personales):
```

```
{
  "eliminado": {
    "cuenta": 1,
    "tarjetas_guardadas": 1,
    "comportamiento_compra": 1,
    "suscripcion_boletin": 1,
    "registro_rectificaciones": 0,
    "oposiciones": 0,
    "bloqueos": 0,
    "codigos_verificacion": 4,
    "sesiones_revocadas": 0,
    "direcciones_de_pedidos": 2
  },
  "bloqueado_por_obligacion_legal": {
    "pedidos_bloqueo_legal": 2,
    "bloqueo_legal_hasta": "2032-11-07 02:28:05",
    "consentimientos_seudonimizados": 2,
    "solicitudes_seudonimizadas": 4
  },
  "propagado_a": {
    "pasarela_pago": "1 de 1 tokens eliminados de la bóveda",
    "lista_supresion": "índice del correo agregado: se reaplica al restaurar respaldos",
    "empresa_despacho": "sin envío: la supresión exige no tener pedidos en curso"
  }
}

Después de ejecutar:
  clientes                filas de Ana: 0
  tarjetas_guardadas      filas de Ana: 0
  boletin_suscriptores    filas de Ana: 0
  registro_rectificaciones  filas de Ana: 0
  tokens en la bóveda de la pasarela: 0

Pedidos conservados con bloqueo legal (sin vínculo con Ana ni dirección):
  id | cliente_id | direccion_cifrado | monto | estado    | bloqueo_legal_hasta
  ---+------------+-------------------+-------+-----------+--------------------
  2  |            |                   | 39990 | entregado | 2032-11-07 02:28:05
  5  |            |                   | 9980  | entregado | 2032-11-07 02:28:05
  aparecen en resumen_pedidos (vista operativa): False
  logística cambia el estado del pedido 2                    -> AccesoDenegado: Acceso denegado
  consentimientos de Ana bajo seudónimo: 2
  login de Ana: None

Respuesta enviada al titular: Eliminado: cuenta, 1 tarjeta(s), preferencias, boletín (1), analítica (1), 0 registro(s...

Respaldo restaurado con la cuenta de Ana -> se reaplica la lista de supresión:
  reaplicar_supresiones() -> 1 cuenta(s) suprimida(s) otra vez

Fin del bloqueo legal (se simula que pasaron los 6 años del pedido 2):
  pedidos 2 y 5 tras aplicar_retencion: [5]
```

Figura 8. Supresión de Ana: rechazo por pedido en curso, acta, bloqueo legal y propagación (evidencia/ev_act6_supresion.txt).

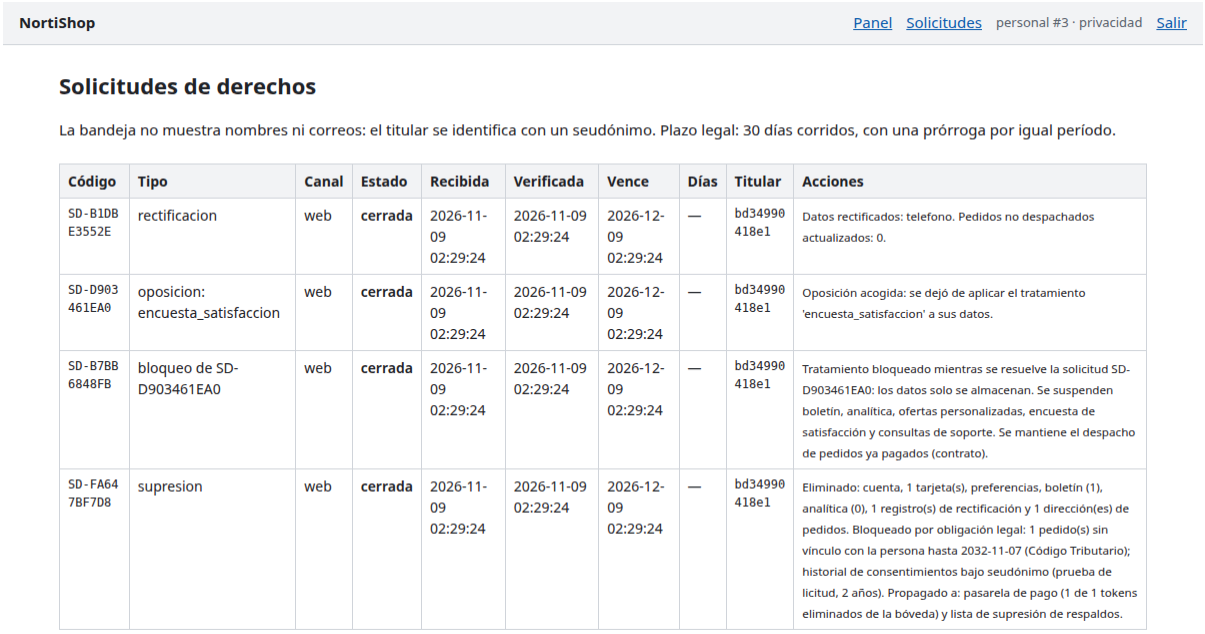


Figura 9. Bandeja de privacidad: respuesta de la supresión con lo eliminado, bloqueado y propagado.

7. Oposición y bloqueo del tratamiento

7.1 Tratamiento elegido

Las finalidades de NortiShop basadas en consentimiento (boletín, analítica, ofertas personalizadas) ya se desactivan revocando el consentimiento (Actividad 5), y la finalidad `compra` es necesaria para el contrato. Para que la oposición tenga un objeto real se agregó un tratamiento basado en el **interés legítimo** del responsable, el supuesto del art. 8° letra a): la **encuesta de satisfacción** que marketing envía por correo a los clientes con un pedido entregado en los últimos 30 días (`correos_para_encuesta`). No necesita consentimiento, pero el titular puede oponerse.

Tabla 8. Qué derecho corresponde según la base legal.

Finalidad	Base legal	Cómo se detiene
compra	Contrato	No admite oposición (la solicitud se rechaza explicando por qué)
boletin, analitica_comportamiento, ofertas_personalizadas	Consentimiento	Revocando el consentimiento; la solicitud de oposición indica ese camino
encuesta_satisfaccion	Interés legítimo	**Oposición** (art. 8° a)
Todas, temporalmente	—	**Bloqueo** mientras se resuelve una rectificación, supresión u oposición (art. 8° ter)

7.2 Oposición

1. El titular elige el tratamiento y escribe un motivo breve (art. 11 d; 10 a 500 caracteres). Se validan la base legal y que no exista ya una oposición; el motivo queda cifrado.
2. Verifica su identidad con el código del correo. La solicitud pasa a evaluación.
3. Privacidad ve el tratamiento y el motivo (`detalle_oposicion`, sin la identidad del titular). La regla del art. 8° a) es dejar de tratar salvo motivos legítimos imperiosos: acoger no exige justificación, rechazar exige un fundamento escrito de al menos 20 caracteres.
4. Al acogerla se agrega una fila en `oposiciones` y se borra el motivo. `correos_para_encuesta` consulta esa tabla en cada envío, así que el titular sale de la siguiente campaña. Se avisa al titular y se registra en la bitácora.

7.3 Bloqueo temporal

El titular puede pedir que, mientras se resuelve su rectificación, supresión u oposición, sus datos solo se almacenen. El bloqueo se asocia a una solicitud propia y en curso de esos tipos (otra cualquiera se rechaza), también exige la verificación por correo y se aplica de inmediato al verificarse. No tiene fecha de término propia: `_cambiar_estado` lo levanta (`hasta = ahora`) cuando la solicitud asociada se cierra, sea acogida o rechazada.

Tabla 9. Efecto de un bloqueo vigente.

Tratamiento	Con bloqueo	Dónde se comprueba
Boletín	No se incluye en la campaña	`correos_para_envio_boletin`
Analítica de comportamiento	No se registra	`guardar_comportamiento` devuelve False
Ofertas personalizadas	Se muestran las generales	`ofertas`
Encuesta de satisfacción	No se incluye	`correos_para_encuesta`
Consulta de contacto por soporte	Se rechaza	`contacto_cliente`
Almacenamiento	Se mantiene	—
Despacho de pedidos ya pagados	Se mantiene (contrato en ejecución, iniciado por el titular)	—

```
Oposiciones que no proceden:
  Beto se opone al boletín (se basa en consentimiento)        -> ValueError: Ese tratamiento se basa en tu consent...
  Beto se opone a 'compra' (contrato)                         -> ValueError: Ese tratamiento es necesario para cum...
  Beto se opone sin motivo                                    -> ValueError: Indica brevemente el motivo de la opo...

Solicitud concreta: Beto se opone a la encuesta y pide el bloqueo mientras se evalúa.
  Beto verifica la oposición                                  -> OK en_evaluacion

Bloqueos que no proceden:
  Beto bloquea asociado a una solicitud de acceso             -> ValueError: El bloqueo debe asociarse a una solic...
  Carla bloquea asociado a la oposición de Beto               -> ValueError: El bloqueo debe asociarse a una solic...
  Beto verifica el bloqueo                                    -> OK cerrada
  codigo       | tipo     | tratamiento          | asociada     | estado       | resultado                    ...
  -------------+----------+----------------------+--------------+--------------+------------------------------...
  SD-7695510280 | oposicion | encuesta_satisfaccion |              | en_evaluacion |                              ...
  SD-992FF5FA1F | bloqueo   |                      | SD-7695510280 | cerrada      | Tratamiento bloqueado mientras ...
  id | cliente_id | solicitud    | asociada     | desde              | hasta
```

```
---+------------+---------------+---------------+---------------------+------
1  | 2          | SD-992FF5FA1F | SD-7695510280 | 2026-11-09 02:28:07 |

Con el bloqueo vigente (los datos de Beto solo se almacenan):
  destinatarios de la encuesta: ['carla.nueva@prueba.cl']
  soporte consulta el contacto de Beto                -> ValueError: Los datos de este cliente están bloqu…
  soporte consulta el contacto de Carla               -> OK {'nombre': 'Carla Prueba', 'correo': 'carla.nu…
  la cuenta de Beto sigue almacenada: True

Privacidad evalúa la oposición:
  detalle_oposicion -> {'tratamiento': 'encuesta_satisfaccion', 'motivo': 'Recibo demasiados correos y no quiero resp…
  marketing intenta resolverla                -> AccesoDenegado: Acceso denegado
  privacidad la rechaza sin fundamento        -> ValueError: El rechazo requiere acreditar motivos…
  privacidad acoge la oposición               -> OK acogida
  id | cliente_id | tratamiento          | solicitud     | desde
  ---+------------+----------------------+---------------+--------------------
  1  | 2          | encuesta_satisfaccion | SD-7695510280 | 2026-11-09 02:28:07
  id | cliente_id | solicitud     | asociada      | desde               | hasta
  ---+------------+---------------+---------------+---------------------+--------------------
  1  | 2          | SD-992FF5FA1F | SD-7695510280 | 2026-11-09 02:28:07 | 2026-11-09 02:28:07

Después: el bloqueo se levantó al cerrarse la oposición, pero la oposición sigue vigente.
  destinatarios de la encuesta: ['carla.nueva@prueba.cl']
  soporte consulta el contacto de Beto                -> OK {'nombre': 'Beto Prueba', 'correo': 'beto@prue…
  respuesta enviada a Beto: Oposición acogida: se dejó de aplicar el tratamiento 'encuesta_satisfaccion' a sus datos.
```

Figura 10. Oposición de Beto a la encuesta, con bloqueo mientras se evalúa (evidencia/ev_act6_oposicion_bloqueo.txt).

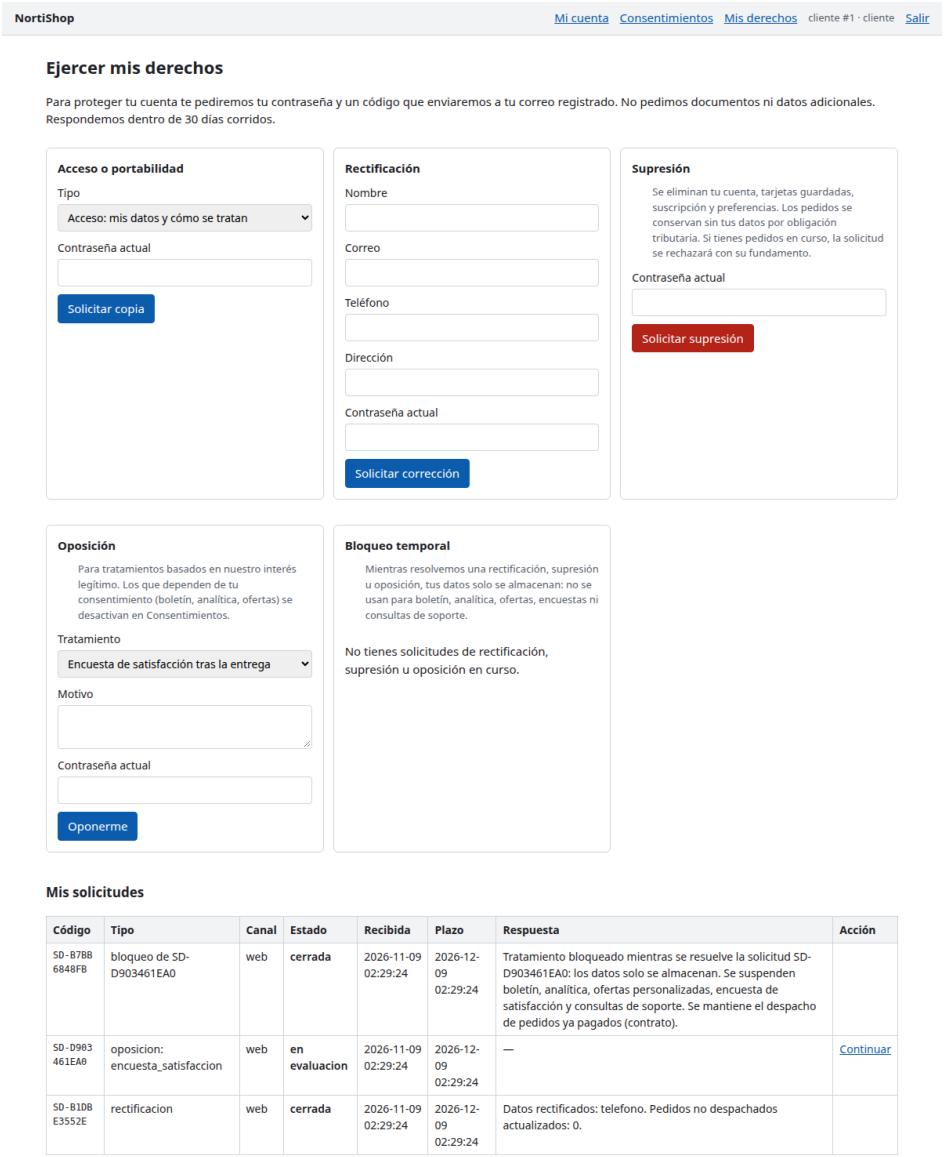


Figura 11. El titular pidió la oposición y el bloqueo; el bloqueo ya está aplicado y la oposición en evaluación.

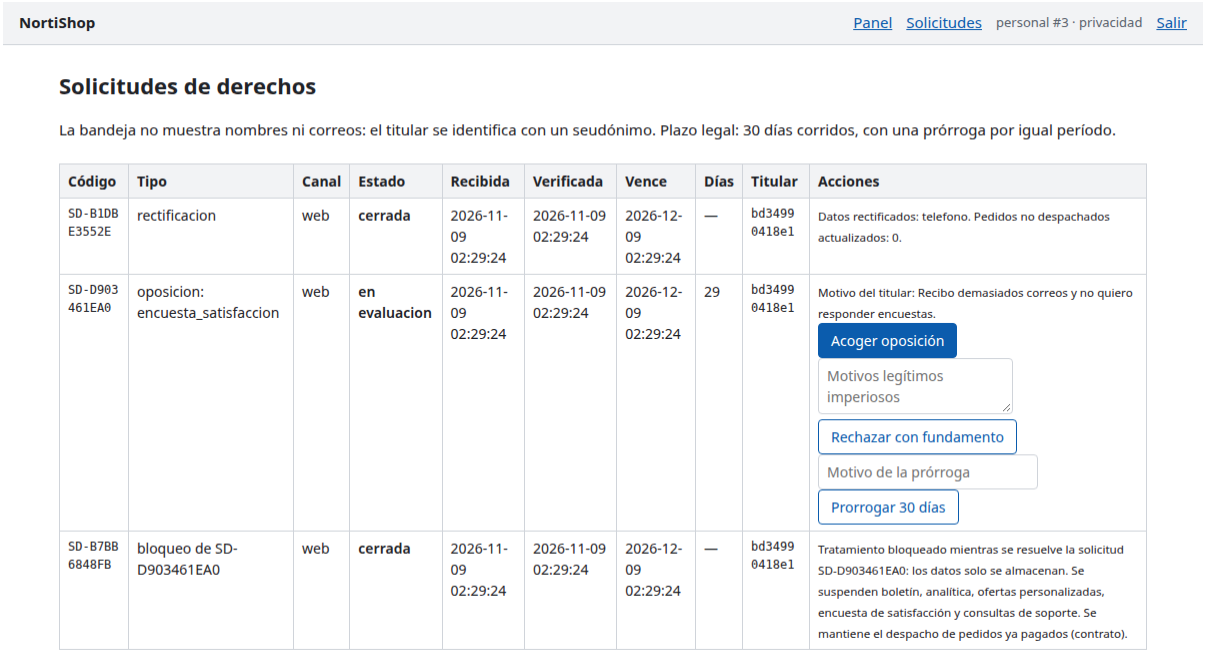


Figura 12. Privacidad evalúa la oposición: ve el tratamiento y el motivo, no la identidad.



Figura 13. Oposición acogida; el bloqueo asociado quedó levantado al cerrarse.

8. Pruebas de cada mecanismo

pruebas_actividad6.py contiene 19 pruebas automatizadas. Cada una crea una solicitud concreta sobre una base temporal con datos ficticios y comprueba el resultado en la base, en el correo simulado y en la bitácora. Las pruebas de la Actividad 5 y de la Actividad 4 se mantienen y siguen pasando: **92 de 92 correctas**. evidencia_act6.py repite los mismos escenarios y guarda la salida en evidencia/ev_act6_*.txt.

Tabla 10. Pruebas de la Actividad 6.

Prueba	Solicitud concreta	Comprueba
R1_01	Carla pide acceso por la web	Canal, tipo, seudónimo, plazo de 30 días y fecha de

Prueba	Solicitud concreta	Comprueba
		cada etapa hasta cerrada
R1_02	Ana pide rectificar el teléfono por la API	canal=api; valor nuevo cifrado; bitácora sin valores; canal inválido rechazado
R2_01	Supresión con contraseña incorrecta (no verificado)	No se registra ni se envía código; bitácora 'reautenticacion_fallida'
R2_02	Cambio de correo con contraseña robada, sin acceso al correo (no verificado)	3 códigos fallidos → cerrada; correo intacto; sin registro de cambio; nada enviado al atacante
R2_03	Beto usa el código de Ana (no verificado)	AccesoDenegado al verificar y al exportar
R2_04	Acceso y supresión sin verificar	No se exporta ni se suprime
R2_05	Soporte solicita; API sin token	AccesoDenegado / 401
R3_01	Ana pide acceso (hay pedidos de Beto y de un invitado)	Todos sus pedidos, tarjetas y consentimientos; nada de terceros ni datos internos
R3_02	Ana pide portabilidad	JSON estructurado, sin NortiPuntos ni secciones de acceso; bitácora con formato
R4_01	Ana rectifica dirección y teléfono con un pedido no despachado	Registro con valores anterior/nuevo cifrados, comunicado a despacho, aviso, inmutable
R4_02	Ana cambia su correo estando suscrita al boletín	Segundo código; registro comunicado al boletín; aviso a ambos correos; visible en el acceso
R5_01	Ana pide la supresión (pedido entregado, tarjeta, boletín, analítica)	Acta: eliminado, bloqueo legal de 6 años, pasarela y lista de supresión
R5_02	Vence el bloqueo legal del pedido	aplicar_retencion lo elimina
R5_03	Supresión con un pedido en curso	Rechazo fundamentado con aviso de reclamo; la cuenta sigue
R6_01	Ana se opone a la encuesta	Privacidad la acoge; Ana sale de la encuesta, Beto sigue; motivo borrado
R6_02	Oposición al boletín, a la compra y sin motivo; rechazo sin fundamento	Cada una se rechaza con su explicación
R6_03	Ana pide bloqueo mientras se evalúa su supresión	Boletín, analítica, ofertas, encuesta y soporte suspendidos; al cerrar la supresión se reanudan
R6_04	Bloqueos inválidos y uno no verificado	Rechazados; ningún bloqueo creado
R6_05	Beto se opone y bloquea por la API; privacidad acoge por la API	Bloqueo inmediato, levantado al acoger; la oposición se mantiene

```
test_R3_01_acceso_entrega_todos_los_datos_del_titular_y_solo_los_suyos ... ok
test_R3_02_portabilidad_solo_lo_aportado_en_formato_estructurado ... ok
test_R1_01_solicitud_registrada_con_canal_tipo_fechas_y_plazo ... ok
test_R1_02_canal_api_y_detalle_cifrado ... ok
test_R6_01_oposicion_a_la_encuesta_acogida ... ok
test_R6_02_oposicion_no_procede_o_se_rechaza_con_fundamento ... ok
test_R6_03_bloqueo_suspende_el_tratamiento_mientras_se_resuelve ... ok
test_R6_04_bloqueo_invalido_o_sin_verificar ... ok
test_R6_05_oposicion_y_bloqueo_por_la_api ... ok
```

```
test_R4_01_rectificacion_con_registro_del_cambio_y_propagacion ... ok
test_R4_02_cambio_de_correo_registrado_y_avisado_a_ambos_correos ... ok
test_R5_01_acta_elimina_bloquea_y_propaga ... ok
test_R5_02_el_bloqueo_legal_vence_y_el_pedido_se_elimina ... ok
test_R5_03_supresion_rechazada_por_pedido_en_curso ... ok
test_R2_01_contraseña_incorrecta_no_crea_solicitud ... ok
test_R2_02_contraseña_robada_sin_acceso_al_correo_no_rectifica ... ok
test_R2_03_tercero_con_el_codigo_de_otra_persona ... ok
test_R2_04_sin_verificar_nada_se_ejecuta ... ok
test_R2_05_personal_y_peticiones_sin_sesion_por_la_api ... ok

----------------------------------------------------------------------
Ran 19 tests in 0.727s

OK
```

Figura 14. Ejecución de las pruebas (evidencia/ev_act6_pruebas.txt).

9. Limitaciones

- **Correo simulado.** El código de verificación y las respuestas van a un buzón en memoria (notificador.py), porque el proyecto no tiene servidor de correo. En producción se usaría un proveedor con TLS sin cambiar el flujo.
- **Compradores invitados.** Sus datos (correo, teléfono, dirección del pedido) están en el inventario, pero no tienen cuenta ni contraseña, así que no pueden usar el canal autenticado. Se recomienda un canal por formulario con el código del pedido y un código enviado al correo de la compra; hoy esos datos solo se reducen con la retención de 365 días.
- **Plazo de conservación tributaria.** Se usaron 6 años (máximo de revisión del art. 200 del Código Tributario). El plazo exacto debe confirmarlo el área contable.
- **Registro de rectificaciones.** Guarda los valores anteriores cifrados mientras la cuenta existe; no tiene un plazo propio de conservación más corto.
- **Decisiones automatizadas (art. 8° bis).** NortiShop no toma decisiones automatizadas con efectos jurídicos; si se agregaran, habría que sumar ese derecho de oposición.

10. Referencias

- Ley N° 19.628 sobre protección de la vida privada, modificada por la Ley N° 21.719. Biblioteca del Congreso Nacional, https://www.bcn.cl/leychile/navegar?idNorma=1209272.
- Código Tributario, D.L. N° 830, art. 200. Biblioteca del Congreso Nacional.
- NortiShop: Informe de inventario y clasificación de datos personales (2026).
- NortiShop: Actividad N°5, consentimiento, derechos de los titulares, auditoría y respuesta a incidentes (2026).
- Repositorio del proyecto: github.com/m1lvn/nortishop-seguridad, rama actividad6.

Anexo A. Cumplimiento de la pauta

Tabla 11. Correspondencia entre la pauta y el informe.

Punto de la pauta	Dónde se cumple	Código
1. Canal y modelo de datos	Sección 2	app.py (/derechos, /api/v1/derechos), db.py (solicitudes_derechos y tablas de apoyo), derechos.bandeja
2. Verificación de identidad	Sección 3	derechos.crear_solicitud, verificar_identidad, _comprobar_codigo, confirmar_correo_nuevo
3. Acceso y portabilidad	Sección 4	derechos.exportar, _construir_exportacion
4. Rectificación con registro	Sección 5	derechos._ejecutar_rectificacion, tabla registro_rectificaciones
5. Supresión (elimina, bloquea, propaga)	Sección 6	nortishop.suprimir_cliente, derechos.resolver_supresion, acta_supresion, aplicar_retencion
6. Oposición o bloqueo	Sección 7	derechos.resolver_oposicion, _ejecutar_bloqueo, nortishop.tratamiento_suspendido, correos_para_encuesta
7. Pruebas con solicitudes concretas, incluido un no verificado	Sección 8	pruebas_actividad6.py (R2_01 a R2_05 y R6_04: no verificados), evidencia_act6.py